

Corporate Compliance & Data Governance Policy

Document ID: LEG-CORP-002 | Effective: June 27, 2026 | Version: 1.0 | Classification: Internal

APPROVED — ACTIVE

1. Purpose & Scope

This policy establishes the corporate compliance and data governance framework administered by the TechCorp Legal Department. It defines how the Legal Department oversees enterprise-wide compliance obligations, manages data governance standards, and coordinates with other departments to ensure TechCorp meets its legal, regulatory, and ethical commitments across all business operations.

This policy applies to all TechCorp employees, contractors, subsidiaries, and third-party partners who handle corporate data, produce regulated content, or operate within compliance-scoped business processes. It supplements the **Legal Department AI Usage Policy (LEG-AI-001)** and does not replace any obligations defined therein.

2. AI Platform Integration

The Legal Department accesses the TechCorp Enterprise AI Platform through its dedicated compliance tenant, configured with role-based access controls managed jointly with the **IT Department** and audited quarterly by the **Security Department**.

Core integrations include:

- Compliance Monitoring Dashboard** — AI-driven aggregation of regulatory obligations across all jurisdictions where TechCorp operates, with automated deadline alerting, coordinated with the **Finance Department** for statutory filings and the **Security Department** for technical control evidence.
- Data Classification Engine** — RAG-powered data inventory and classification tool that tags corporate data assets by sensitivity tier (Public, Internal, Confidential, Restricted), integrated with the **IT Department's** access management infrastructure for automated enforcement.
- Policy Compliance Auditor** — AI-assisted review of department-level policies against the current regulatory landscape, flagging gaps for Legal review and routing remediation recommendations to the owning department head.

- **Third-Party Risk Assessment Module** — AI-driven due diligence on vendors and partners, scoring contracts and data-processing agreements against TechCorp’s compliance thresholds, with escalations managed jointly with **Security** and **IT**.

Connected Departments: IT (access governance & data classification enforcement) • Security (technical controls & breach response) • Finance (regulatory filings & SOX compliance) • HR (employee data governance & ethics training) • AI (platform safety & model governance) • Operations (process-level compliance enforcement)

3. Permitted Compliance & Governance Use Cases

Use Case	AI Role	Human Oversight Required
Regulatory obligation tracking & deadline alerting	Automated monitoring & notification	Compliance officer validates alert priority and routing before dissemination
Corporate data classification & inventory	Automated tagging & mapping	Data steward reviews and confirms classifications quarterly
Policy-to-regulation gap analysis	First-pass comparison & flagging	Legal counsel reviews all flagged gaps before remediation action
Third-party due diligence screening	Risk scoring & anomaly detection	Procurement and Legal jointly approve high-risk findings before contract execution
Internal investigation document review	Relevance scoring & clustering	Investigating attorney confirms all privilege and responsiveness determinations
Ethics hotline report triage	Categorization & urgency scoring	HR and Legal jointly determine escalation path for every report

4. Prohibited Activities

The following are strictly prohibited under this policy:

- **Unauthorized cross-border data transfers.** No corporate data classified as Confidential or Restricted may be transferred to jurisdictions lacking adequate data protection without prior Legal Department approval and a validated Data Transfer Impact Assessment co-signed by the Data Protection Officer.
- **Bypassing the data classification framework.** All corporate data assets must be classified per the Data Classification Engine taxonomy within 30 days of creation or acquisition. Unclassified data repositories are prohibited beyond the remediation window.

- **Self-directed regulatory interpretation.** AI-generated regulatory summaries are advisory only. Binding compliance decisions must be made by Legal Department counsel after full review of the primary regulatory source.
- **Suppression or alteration of compliance audit trails.** All AI-generated compliance logs, risk scores, and policy-gap analyses are immutable records maintained by the Enterprise AI Platform. Tampering constitutes a violation of TechCorp's Code of Conduct.
- **Use of consumer-grade AI tools for compliance data.** No employee may submit regulated, privileged, or confidential compliance-related data to any public or unapproved external AI service, including free-tier generative AI tools.

5. Data Handling & Confidentiality

All Legal Department data governance activities must comply with TechCorp's **AI Safety Guidelines** (AI Department) and the **Data Protection Standards** (Security Department). Specific requirements:

- All corporate data must be classified into one of four tiers — Public, Internal, Confidential, Restricted — using the classification taxonomy maintained jointly by Legal, Security, and IT.
- Restricted and Confidential data require role-based access controls provisioned by the IT Department and audited quarterly by the Security Department against the access matrix maintained by Legal.
- Data retention schedules are defined by the Legal Department in coordination with the owning business unit; IT executes automated retention and disposal workflows through the Enterprise AI Platform.
- Any unauthorized access, disclosure, or loss of Confidential or Restricted data must be reported to Legal, Security, and IT within 1 hour of discovery per the joint Incident Response Plan.
- The Legal Department, in partnership with Security, maintains a register of approved cross-border data transfer mechanisms; no department may establish cross-border data flows without prior Legal review.

6. Prompt Engineering & Quality Standards

Legal and compliance professionals using the AI Platform must adhere to TechCorp's **Prompt Engineering Standards**. Compliance-specific requirements include:

- Prompts for regulatory analysis must include the specific regulation, jurisdiction, and effective date — ambiguous prompts produce unreliable compliance outputs that cannot be actioned.
- Data classification prompts must reference the full TechCorp classification taxonomy and the specific data domain being classified; partial or assumed

classifications are prohibited.

- Third-party risk assessment prompts must include the vendor's jurisdiction, data-processing scope, and contract tier; outputs produced without these inputs are invalid for compliance decisions.
- All compliance-related prompt templates must be reviewed and approved by Legal Operations before deployment and version-controlled in the department's shared prompt library.
- Accuracy below 92% on quarterly compliance benchmarks triggers a model review by the AI Department within 10 business days.

7. Roles & Responsibilities

Role	Responsibility
General Counsel	Overall policy ownership; final authority on compliance interpretations; approves exceptions to data governance rules; escalation point for unresolved compliance disputes.
Chief Compliance Officer	Day-to-day compliance program management; regulatory monitoring program oversight; ethics hotline governance; quarterly compliance reporting to the board.
Data Protection Officer (DPO)	Data governance framework ownership; privacy impact assessments; data subject request management; coordination with global regulatory authorities.
Legal Operations Lead	Policy enforcement tooling; prompt template governance; compliance training coordination; audit scheduling with Security and IT.
IT Department	Technical enforcement of data classification; access provisioning per Legal-defined policies; data retention and disposal automation; platform integration maintenance.
Security Department	Technical controls for data protection; quarterly access audits; breach detection and incident response; third-party security assessments; AI security posture monitoring.
Finance Department	Regulatory filing execution; SOX compliance coordination; financial data classification; audit trail integrity for all financial records.
HR Department	Employee data governance; ethics and compliance training delivery; disciplinary process administration for policy violations; background-check compliance.
AI Department	Model safety and performance monitoring for compliance-use AI; prompt standard governance; platform reliability and accuracy benchmarking.

8. Incident Response

Any of the following constitutes a compliance or data governance incident and must be reported within the timeframe specified to the General Counsel, Chief Compliance Officer, and Security Department:

- Data breach involving Confidential or Restricted data — report within 1 hour to the General Counsel, DPO, CISO, and CIO.
- Regulatory filing error or missed statutory deadline — report within 4 hours to the Chief Compliance Officer, General Counsel, and the relevant regulatory liaison.
- AI-generated compliance advice that proves materially incorrect and reaches an external party — report within 2 hours to the Chief Compliance Officer and AI Department.
- Whistleblower retaliation allegation — report immediately to the Chief Compliance Officer and the Chair of the Audit Committee; handled under the independent investigation protocol maintained by Legal and HR.
- Third-party data processor breach affecting TechCorp data — report within 2 hours to the DPO, Security, and Legal; trigger the vendor incident response procedure co-managed by Legal and IT.

All incidents are logged in the Enterprise AI Platform's compliance incident module, generating an immutable audit trail. A root-cause analysis involving Legal, Security, and the affected department is mandatory within 10 business days. Material incidents are escalated to the board within 72 hours per the board reporting policy maintained by the General Counsel.

9. Training & Compliance

- All TechCorp employees must complete the annual Corporate Compliance & Ethics training module administered by the Legal Department through the Enterprise AI Platform, with completion tracked and reported by the HR Department.
- Employees handling Confidential or Restricted data must complete the Data Governance & Privacy training within 30 days of receiving access and annually thereafter, delivered jointly by Legal and Security.
- Managers and above must complete the Regulatory Obligations & Reporting workshop within 60 days of promotion or hire, covering their department's specific compliance landscape as mapped by the Compliance Monitoring Dashboard.
- Compliance audits are conducted quarterly by Legal Operations in coordination with the Security Department and the owning department head; results are reviewed by the Chief Compliance Officer and summarized for the board annually.
- Non-compliance with this policy is subject to progressive discipline up to and including termination, consistent with the TechCorp Employee Handbook administered by HR.

10. Review & Revision

This policy is reviewed every 6 months by the General Counsel, Chief Compliance Officer, Data Protection Officer, and Legal Operations Lead, with input from the AI Department (for platform-related provisions), Security Department (for technical controls), IT Department (for data governance enforcement), and HR Department (for training and discipline provisions). Revisions are versioned, approved by the General Counsel, and published through the Enterprise AI Platform’s policy distribution module, which notifies all affected personnel and tracks acknowledgment. Emergency revisions may be triggered by material regulatory changes, data breach findings, or board directives and follow an accelerated 14-day review cycle.

Referenced Policies: Legal Department AI Usage Policy (LEG-AI-001) • TechCorp AI Safety Guidelines (AI Department) • Prompt Engineering Standards (AI Department) • Data Protection Standards (Security Department) • IT Access Management Policy (IT Department) • Employee Handbook & Code of Conduct (HR Department) • Financial Controls & SOX Compliance Policy (Finance Department)